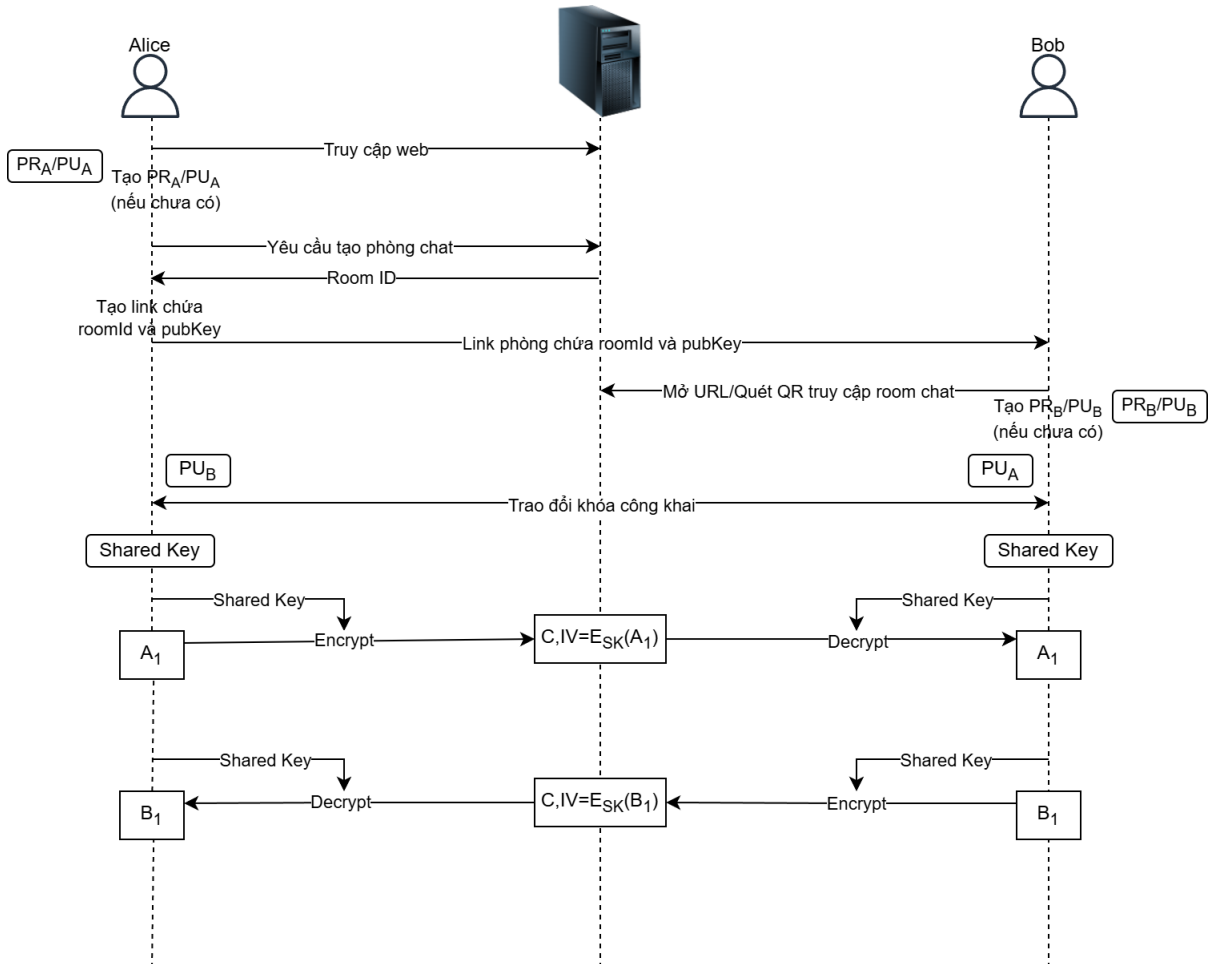


# Ứng dụng chat E2EE - Requirements

## 1 Luồng hoạt động (Work Flow)



Bước 1: Khởi tạo danh tính (Khi mở web lần đầu)

- Người dùng A truy cập trang web.
- Web app của A tạo cặp khóa ECDH và lưu vào IndexedDB.

Bước 2: Tạo phòng và Mời (OOB Handshake)

- A bấm "Tạo phòng chat".
- Web App sinh ra một Room\_ID ngẫu nhiên.
- Web App tạo một link chứa ID phòng và Public Key (VD: chat.com/join#room=abc123).
- A gửi link cho B.

Bước 3: Kết nối và Trao đổi khóa

- B bấm vào link và truy cập đến Room chat.
- Web app của B tự tạo cặp khóa ECDH cho B (nếu B chưa có).
- A và B cùng kết nối WebSockets lên Server, join vào room=abc123.

- A và B trao đổi khóa công khai để cùng tạo ra khóa bí mật chung Shared Key.

Bước 4: Nhắn tin và Đồng bộ

- A gửi tin nhắn: "Hello".
- Web app của A dùng Shared Key để mã hóa tin nhắn thành ciphertext và iv.
- Ciphertext được gửi qua WebSocket lên server và trình duyệt A cũng tự lưu tin nhắn vào IndexedDB của mình.
- Server nhận được ciphertext và iv, chuyển sang cho B qua WebSockets.
- Web app B nhận được ciphertext và iv, dùng Shared Key để giải mã được "Hello" và lưu vào IndexedDB trình duyệt
- A và B tiếp tục nhắn tin và cơ chế mã hóa được áp dụng như trên.

Bước 5: Phục hồi phiên làm việc

- Khi người dùng tắt trình duyệt và mở lại, các tin nhắn cũ được lấy ra từ IndexedDB và hiển thị trên cho người dùng.

## 2 Yêu cầu chức năng (Functional Requirements)

- Không cần đăng nhập: Mỗi người dùng có một cặp khóa và khóa công khai là danh tính người dùng.
- Quản lý phòng chat: Tạo và tham gia phòng chat qua link hoặc QR
- Trao đổi khóa an toàn: Sử dụng ECDH để tạo shared secret
- Mã hóa tin nhắn: Tin nhắn được mã hóa ở client và server chỉ đóng vai trò trung chuyển.
- Khôi phục lịch sử: Dữ liệu tin nhắn được lưu ở client, và được khôi phục khi người dùng truy cập lại phòng chat.

## 3 Yêu cầu phi chức năng (Non-functional requirements)

- Không xác thực người dùng: Người dùng không cần cung cấp thông tin.
- Mã hóa đầu cuối: Tin nhắn phải được mã hóa và giải mã ở 2 phía người dùng, server chỉ nhìn thấy ciphertext.
- Lưu trữ cục bộ: Server chỉ lưu trữ thông tin các phòng chat, các thông tin chi tiết tin nhắn được lưu ở phía Client.